AcePharm

IMPLEMENTATION PLAN · VERSION 3.0

Engineering Blueprint for the UK Pharmacy Revision & Clinical Reasoning Platform

Revised to run the entire product — application, database, vector search and AI orchestration — on Firebase and Cloudflare free-tier infrastructure, with zero fixed hosting cost until usage growth requires it.

- Next.js on Cloudflare Pages
- Cloudflare D1 + Vectorize
- Firebase Authentication
- Claude-powered Ace RAG
- £0 infra until scale

CLIENT	STATUS	PREPARED	SUPERSEDES
Takween Centre UK Ltd	Draft for Review	28 August 2026	Plan v2.1

CONTENTS

01 Executive Overview & What Changed From v2.1

AcePharm is a subscription revision platform for UK MPharm students (Years 2–4), foundation trainees and GPhC candidates: curriculum-mapped practice questions, option-by-option clinical rationales, honest first-attempt-vs-practice analytics, and **Ace** — an AI tutor strictly grounded in AcePharm's own reviewed content. This plan synthesises the Developer Brief v2.1, the Website Copy v2.0, and the interactive HTML prototype into a single build reference, re-platformed onto Firebase and Cloudflare's free tiers per client instruction.

◆ WHAT THIS REVISION CHANGES

The original v2.1 plan specified Next.js on Vercel, managed PostgreSQL + pgvector (UK/EU), Prisma, and Auth.js. That stack is technically sound but carries real monthly cost from day one — a managed EU Postgres instance capable of production traffic and Vercel Pro hosting typically run **£40–£120/month** before a single subscriber signs up. This version keeps every product requirement, data rule and UI/UX decision from the Developer Brief unchanged, and re-derives only the *infrastructure* layer to run on Cloudflare's and Firebase's free tiers, targeting **£0 fixed infrastructure cost** through MVP launch and early growth. The only unavoidable variable costs are the Anthropic Claude API (pay-per-token, usage-based) and Stripe's transaction fees (self-funding, taken from revenue).

1.1 Product model (unchanged)

TIER	PRICE	ALLOWANCE	ACE ACCESS
Explorer	£0/month	30 questions/month, resets on signup anniversary. Permanent — not a trial, no card required.	Disabled
Monthly Pro	£4.99/month	Unlimited questions, full analytics, weak-area generator, spaced repetition, consultation simulator, timed sessions.	Full
Yearly Pro	£49.99/year	Identical features to Monthly Pro (saves £9.89/year). Exact proration shown on upgrade.	Full

Per the brief's Non-Negotiable #8: monthly and yearly must never differ in feature set — only in billing cadence and price.

1.2 The core loop

Practise (Learn / Timed) → Understand (rationales + notes) → Analyse (calibration + weak topics) → Improve (Ace + spaced flashcards) → back to Practise

1.3 System components

Public Marketing & Content Hub

Server-rendered, SEO-optimised site with transparent pricing, editorial standards and a database-backed blog. Noindexed application shell kept entirely separate.

Learner Application

Mobile-first session builder, question engine, explanation reader, spaced-repetition flashcards and progress dashboard — the single most polished surface in the product per the brief.

Clinical Admin Portal

Authoring, multi-stage review (clinical / educational / editorial), curriculum manager, spreadsheet importer and AI oversight queues.

Ace — the AI Layer

Retrieval-augmented tutor grounded exclusively in AcePharm's reviewed explanations, subtopic notes and reference library — never trained-data recall. Never publishes; never diagnoses.

02 Architecture Decision — Why Firebase + Cloudflare

The Developer Brief's own stack rule (Section 3.1) explicitly permits substitution: *"if you are not fluent in something here, say so before starting and propose the equivalent you know well… do not switch silently mid-build."* This section documents that substitution formally, with the reasoning the client and future engineers need to evaluate it.

2.1 Guiding principle: one system of record

Firebase and Cloudflare each offer a database (Firestore, and D1/KV respectively). Running both would create a split-brain data model — exactly the kind of "invisible until it breaks" trap the brief warns about repeatedly (dual-store attempts, secondary-topic counting). To avoid that, **Firebase's role is scoped to Authentication only.** Every other stateful concern — users, questions, attempts, sessions, subscriptions, Ace threads, embeddings — lives in one place: Cloudflare, primarily D1. This keeps exactly one source of truth for the data the recommendation engine, analytics, and dual-store rule all depend on.

Why Firebase Authentication

- Free on the Spark plan for unlimited email/password and email-link ("magic link") sign-in — no cap that forces an upgrade as users grow.
- Built-in, no-cost transactional emails for verification and password reset (templates are brand-customisable), removing two of Resend's heaviest-volume flows.
- Handles password hashing, session/ID-token issuance, and brute-force protection so the team is not maintaining Argon2/bcrypt infrastructure by hand.
- Firebase Admin SDK verifies ID tokens inside a Cloudflare Worker via standard JWT/JWKS verification — no dependency on Firebase's compute (Cloud Functions) is required, so the Spark free plan is sufficient indefinitely.

Why Cloudflare for everything else

- **D1** — serverless SQLite, genuinely free at meaningful scale, with a relational model well suited to the brief's dual-store, secondary-topic and cohort-analytics requirements.
- **Vectorize** — purpose-built vector database, replacing pgvector without needing Postgres at all.
- **Workers** — 100,000 requests/day free compute for all API/business logic and Stripe/Ace orchestration.
- **Pages** — unlimited bandwidth static/SSR hosting for Next.js, with git-integrated preview deployments matching the brief's staging requirement.
- **R2** — zero egress-fee object storage for blog images, logos and exports.

◆ **DECISION RECORDED**

Firebase = identity only. Cloudflare D1 = single relational system of record. Cloudflare Vectorize = retrieval index for Ace. This keeps the architecture auditable against one database for every acceptance criterion in the brief that depends on query correctness (first-attempt accuracy, category coverage, recommendation logic).

2.2 What stays identical to the Developer Brief

Everything that is a *product* decision rather than a *hosting* decision is unchanged: the dual-store attempt rule, the 26 non-negotiables, the Ace governing principle, the design tokens, the copy document, the review workflow, the accessibility target, and all seven milestone acceptance criteria. Only the "Technology Decisions" table and the schema's physical implementation change.

2.3 GDPR / data-residency note — flagged for client sign-off

⚠ **REQUIRES A DECISION BEFORE MILESTONE 1**

The brief requires the database to sit in the UK or EU, explicitly not the US. Cloudflare D1 supports a `location hint` that pins the primary database instance to Western Europe (`weur`) — this satisfies the requirement for all substantive learner data (attempts, profiles, questions, Ace threads), since D1 is the single system of record. Firebase Authentication's underlying identity store is part of Google's global infrastructure and is *not fully region-pinned* the way a dedicated EU Postgres instance would be, though Google is a certified participant in the EU–US Data Privacy Framework, which provides a lawful transfer mechanism. Because Firebase Auth only ever holds an email address and a password hash — the minimum inherent to any authentication provider — the practical exposure is narrow, but this should be stated plainly in the Privacy Policy and confirmed with the client's legal/compliance sign-off before launch, per Milestone 7's legal-pages requirement.

03 System Architecture & Technology Stack

3.1 Architecture diagram

CLIENT LAYER

- Public Marketing / Blog (SSR)
- Learner App (Responsive PWA-lite)
- Clinical Admin Portal

↓ served by

EDGE HOSTING & COMPUTE — CLOUDFLARE

- Cloudflare Pages — Next.js (App Router)
- Cloudflare Workers — API, Stripe webhooks, Ace orchestration (Hono)
- Cloudflare KV — rate limiting, session cache, response cache
- Cloudflare R2 — blog images, logos, exports

↓ reads / writes

DATA LAYER — CLOUDFLARE

- Cloudflare D1 (SQLite) — single relational system of record, Drizzle ORM
- Cloudflare Vectorize — embeddings for notes / explanations / references
- Cloudflare Workers AI — free-tier embedding generation (bge-base-en)

↕ identity + ↕ external services

IDENTITY — FIREBASE (SPARK / FREE)

- Firebase Authentication — email/password + email-link
- Built-in verification & reset emails

EXTERNAL SERVICES (USAGE-BASED, UNAVOIDABLE)

- Anthropic Claude — Ace generation
- Stripe — Checkout, Billing, Customer Portal
- Resend (free tier) — receipts, digests, moderation notices
- PostHog + Sentry (free tiers) — analytics & error tracking

3.2 Technology decisions

LAYER	SELECTION	TIER	RATIONALE
Framework	Next.js 14+ (App Router), strict TypeScript	Free	Unchanged from v2.1. Server Components for SEO/speed; Server Actions for mutations where compatible with edge runtime.
Frontend hosting	Cloudflare Pages (`@cloudflare/next-on-pages`)	Free	Unlimited bandwidth, 500 builds/month, git-integrated preview URLs — replaces Vercel.
API / business logic	Cloudflare Workers, Hono framework	Free	100,000 requests/day free. Hosts Stripe webhooks, Ace RAG orchestration, admin mutations.
Database	Cloudflare D1 (SQLite), region-pinned to Western Europe	Free	5GB storage, 5M rows read/day, 100K rows written/day free. Replaces managed Postgres.

ORM	Drizzle ORM	`Free`	First-class D1 driver, type-safe, SQL-first — better SQLite ergonomics than Prisma's D1 adapter at time of writing.
Vector search	Cloudflare Vectorize	`Free`	Purpose-built vector index for Ace's RAG retrieval — replaces pgvector without needing Postgres.
Embeddings model	Workers AI `@cf/baai/bge-base-en-v1.5`	`Free`	~10,000 neurons/day free allocation. Keeps embedding generation cost at zero; Claude spend reserved for generation only.
Object storage	Cloudflare R2	`Free`	10GB storage, zero egress fees — blog images, logos, data-export downloads.
Cache / rate limiting	Cloudflare KV + Workers	`Free`	100K reads / 1K writes per day free. Sliding-window counters for auth and AI endpoint rate limiting.
Authentication	Firebase Authentication (Spark plan)	`Free`	Unlimited email/password + email-link sign-in. ID tokens verified inside Workers via JWKS — no Cloud Functions needed.
Payments	Stripe — Checkout, Billing, Customer Portal, Webhooks	`Usage-based`	Unchanged. Transaction-fee funded; webhook endpoint runs on a Worker.
AI LLM provider	Anthropic Claude (Sonnet class)	`Pay-per-token`	Unchanged. The only line item with genuine per-use cost — see Section 6.
Transactional email	Firebase (verify/reset) + Resend (everything else)	`Free tier`	Resend free tier: 3,000 emails/month, 100/day — sufficient through early growth.
Product analytics	PostHog Cloud, EU region	`Free tier`	1M events/month free. Region set to EU for GDPR alignment.
Error tracking	Sentry Developer plan	`Free tier`	5,000 errors/month free — ample for pre-scale traffic.
CI/CD	Cloudflare Pages git integration + GitHub Actions	`Free`	Actions runs D1 migrations and Vectorize re-indexing on merge to main.

⚠ ONE ITEM THAT MAY NEED A PAID STEP

Cloudflare's free plan includes only a limited allowance of custom WAF rate-limiting rules (this changes with Cloudflare's pricing over time — verify current allowance before build). The plan below does not depend on it: rate limiting for login, registration, password reset, question reporting and every Ace endpoint is implemented at the application layer using Worker + KV sliding-window counters, which is free regardless of the WAF rule allowance. If the team later wants Cloudflare's managed bot-fight mode or advanced WAF rules, that sits on the Pro plan (~£20/month) — an optional hardening step, not a launch blocker.

`04` Data Architecture on Cloudflare D1

D1 is SQLite, not Postgres — the schema below preserves every field and rule from the Developer Brief's Section 4 while adapting the physical types. Nothing in Section 5's rules (dual-store, secondary-topic counting, numeric metadata) changes; only column types and the absence of native enums/arrays/vectors change how they're expressed.

4.1 SQLite adaptation rules

POSTGRES/PRISMA CONCEPT (V2.1)	D1/DRIZZLE EQUIVALENT (V3.0)
UUID primary key, DB-generated	TEXT primary key, generated in the Worker via `crypto.randomUUID()` before insert
Native ENUM type	TEXT column with a SQLite CHECK constraint, mirrored as a Drizzle/TypeScript union type at the application layer
JSON array column (e.g. secondary subtopics)	TEXT column storing JSON, using Drizzle's `json()` column helper for automatic (de)serialisation
`TIMESTAMP`	`INTEGER` (Unix epoch ms) via Drizzle's `integer({'{'}mode:'timestamp'{'}'})` — keeps tabular numerals and simple range queries
`pgvector` embedding column + cosine search	Embedding lives in **Cloudflare Vectorize**, keyed by the same id as the D1 `content_chunks` row it describes — see Section 5
CITEXT (case-insensitive email)	TEXT with a `UNIQUE` index on a lower-cased column, enforced by app-layer normalisation on write

◆ THE DUAL-STORE RULE IS UNCHANGED AND NON-NEGOTIABLE

Learner answers are still persisted across two distinct tables: `question_first_attempts` (permanent, immutable, never touched by a delete) and `question_attempts` (the working, user-clearable practice record). This is Non-Negotiable Rule #1 in the brief and the single most commonly botched part of a platform like this — the SQLite migration changes nothing about it.

4.2 Entity model (D1 / Drizzle)

Identity & profiles

`users` — id · firebase_uid (unique, links to Firebase Auth) · email (unique, lower-cased) · email_verified_at · first_name · role (CHECK: student / author / clinical_reviewer / educational_reviewer / copy_editor / content_lead / support_agent / finance_admin / marketing_editor / super_admin) · status (CHECK: active / suspended / pending_deletion / deleted) · deletion_requested_at · timezone (default Europe/London) · marketing_opt_in (default false) · created_at · updated_at · last_login_at

Password hashing is delegated entirely to Firebase Authentication — `users` holds no password field. `firebase_uid` is the join key between the identity provider and the system of record.

`user_profiles` — user_id (FK) · stage (year_2 / year_3 / year_4 / foundation_trainee / other) · primary_goal · assessment_date · daily_question_target (default 20) · university_id (FK) · show_confidence_prompt (default true) · hide_options_by_default (default false) · show_difficulty_labels (default true) — all nullable; every onboarding step is skippable.

`universities` — id · name · email_domain · active — seeded with the ~30 UK schools of pharmacy.

Curriculum & content

`pathways` → `categories` → `subtopics` → `subtopic_notes` (one set per subtopic, shared by every question beneath it; content rendered in a horizontally scrollable container for tables, never squashed on mobile).

`content_chunks` — id · source_type (subtopic_note / explanation / reference) · source_id · chunk_index · content_text · token_count · vectorize_id · updated_at. `vectorize_id` is the pointer into the Vectorize index; the embedding itself never lives in D1.

Question bank & validation

`questions` — id · public_id (human-readable, e.g. `ACP-CV-0012`) · version · status (idea / draft / awaiting_clinical_review / changes_requested / awaiting_editorial_review / approved / scheduled / published / update_required / suspended / archived) · pathway_id · primary_subtopic_id · difficulty (easy / medium / hard) · question_type (sba / emq / calculation) · sector (community / hospital / gp / any) · learning_objective · origin (human / ai_drafted) · generated_by_thread_id · generation_prompt · published_at · next_review_at · created_at · updated_at.

`question_secondary_subtopics` — question_id · subtopic_id. **One primary, any number of secondary.** Filtering by a subtopic returns questions where it is primary or secondary; category-progress counting uses primary only. This is the architectural trap the brief calls out most forcefully — a secondary tag must never inflate two categories' coverage totals at once.

`question_content` — question_id · stem · lead_in · numeric_answer · numeric_tolerance · numeric_unit · decimal_places · calculator_allowed. Populated for every calculation question at import time even though entry stays multiple-choice for now, so free-text numeric answers can be switched on later behind a feature flag without re-authoring content.

`question_options` — id · question_id · label (A–E) · content · is_correct · rationale · sort_order. Every option — including the correct one — requires a rationale; a question cannot leave draft status without exactly one correct answer and five populated rationales.

`question_explanations` · `question_references` · `references` (with `link_status`: ok / broken / superseded, powering an admin alert for superseded citations) · `question_versions` · `question_governance` (author, clinical reviewer, educational reviewer, copy editor, approval timestamp, conflict-of-interest flag).

Learner activity — the dual store

`question_first_attempts` *(permanent, immutable)* — id · user_id · question_id · question_version · selected_option_id · is_correct · confidence (low / medium / high, nullable) · time_taken_seconds · mode (learn / timed) · answered_at. One row per user per question, written only on the very first attempt, ever deleted by nothing.

`question_attempts` *(working, user-clearable)* — every field above plus session_id · attempt_number · explanation_opened · due_for_review_at. A category reset deletes this table's rows for that category and never touches `question_first_attempts`.

`sessions` · `bookmarks` · `notes` (standalone-capable, nullable question_id) · `question_reports` (question id, version, user, session and timestamp captured automatically — the learner never types them).

The Ace layer

`ace_threads` — scoped to a context_type (question / dashboard / planner / calculation / simulator); moving to the next question starts a new thread so Ace never carries one question's reasoning into an unrelated one.

`ace_messages` — role · content · intent · retrieved_chunk_ids (JSON) · citations (JSON) · model · prompt_tokens · completion_tokens · latency_ms · cost_pence · flagged · created_at. Logging the retrieval, not just the answer, is what makes a flagged response investigable.

`ace_usage` · `flashcards` (SM-2 fields: interval_days, ease, due_at, reviews, lapses) · `revision_plans` + `revision_plan_days` (stores the inputs snapshot the plan was generated from) · `simulator_scenarios` + `simulator_attempts`.

Subscriptions, access & audit

`subscriptions` · `free_tier_usage` (30 questions/month, resets on account-creation anniversary) · `access_grants` (every manual access change logged with a required reason) · `audit_log` (append-only, not editable by ordinary admins) · `notifications` · `blog_posts` · `support_tickets` · `feature_flags`.

05 The Ace AI Layer on Cloudflare Vectorize

◆ **THE GOVERNING PRINCIPLE — UNCHANGED FROM THE BRIEF**

Ace is grounded, not generative. Every response is produced from AcePharm's own reviewed content — question explanations, option rationales, subtopic notes and the reference library — never from the model's training data. This is not a style preference; it is what makes the feature defensible, and it is the difference between a pharmacy student reading a pharmacist-reviewed explanation rephrased, and one asking a general chatbot about lithium monitoring.

5.1 Retrieval pipeline on the free tier

1. **Chunk on publish**
   When a question, explanation or subtopic note is published, a Worker splits it into content_chunks and writes metadata rows to D1.
2. **Embed for free**
   Workers AI (@cf/baai/bge-base-en-v1.5) generates the embedding — no external embedding API spend, ~10K neurons/day free allocation.
3. **Index in Vectorize**
   The vector is upserted into a Vectorize index keyed by the D1 chunk id, replacing pgvector's cosine-similarity search.
4. **Retrieve on each Ace turn**
   A Worker embeds the learner's query, queries Vectorize for the nearest chunks, and hydrates the matched content from D1.
5. **Generate with Claude**
   Retrieved chunks are placed in the prompt with an explicit instruction to answer only from them and to refuse plainly when coverage is missing. The response streams back to the client.
6. **Log everything**
   retrieved_chunk_ids, citations, tokens, latency and cost_pence are written to ace_messages before the response is considered complete.

5.2 Ace surfaces (from the prototype and brief, unchanged)

SURFACE	BEHAVIOUR
Ask Ace panel	Collapsed below every explanation by default. Quick prompts: `simpler`, `whynot`, `similar`, `test`, `exam`, `steps` (calculations only). Free text accepted; every message carries a citation.
Highlight-to-ask	Selecting text in a stem or explanation surfaces a floating control that opens the panel with the selection quoted — must work via mobile selection handles.
Revision planner	Seven-day plan from subtopic-level first-attempt accuracy, unseen volume, assessment date and actual (not target) session length. Always includes a rest day and at least one spaced-review day.
Weekly insight	One cached paragraph, generated on a schedule not on page load. Leads with "confidently incorrect" answers whenever they exist — the single most useful signal in the dataset.
Calculation coach	Identifies which line of the learner's working broke, grounded in the stored `calculation_working` field. Accepts valid alternative methods.
AI-drafted questions	Created as `draft` / `ai_drafted`, enters the same clinical/educational/editorial review as human content, never visible to learners pre-approval. The generating account cannot be the approving account — enforced at the D1 layer via a check constraint plus application logic, not only in the UI.

Consultation simulator	One scenario ships (new inhaler counselling, four exchanges, six-point rubric) as a database row, not a hardcoded object, so more can be added without a deployment.

5.3 Safety & cost controls

Safety (brief Section 6.10)

- No patient-specific advice — declines and directs to the BNF
- No dosing from memory — retrieved content or nothing
- Citations on every response, stored and displayed
- Prompt injection: learner input untrusted, retrieved content trusted, kept structurally separate
- 50+ case evaluation set run before launch and after every prompt change

Cost (Cloudflare-specific optimisations)

- Cache identical quick-prompt + question pairs in KV at the question-and-intent level, not per learner
- Weekly insight generated on a cron Worker trigger, never on page load
- Retrieve narrowly — never whole subtopic notes per turn
- cost_pence tracked per message from day one; Ace unavailable on the free tier by design
- 20-second timeout with retry; if Claude is unavailable, the panel degrades gracefully and the rest of the product keeps working — no core learning-loop feature may block on an AI call

06 Free-Tier Ceilings, Costs & Scaling Triggers

Free tiers are not unlimited. This section states the actual ceilings as published at the time of writing, what usage they comfortably support, and the low-cost upgrade path when AcePharm outgrows them — so the client can plan, not be surprised. **Verify current limits against each provider's pricing page before contract sign-off, as free-tier terms change.**

SERVICE	FREE CEILING	COMFORTABLY SUPPORTS	FIRST PAID STEP
Cloudflare Pages	Unlimited bandwidth, 500 builds/mo	Any realistic traffic pre-Series A	No paid tier needed for hosting itself
Cloudflare Workers	100,000 requests/day	~500–1,500 daily active learners at typical session request rates	Workers Paid, $5/mo base + $0.30/million requests beyond free
Cloudflare D1	5GB storage · 5M rows read/day · 100K rows written/day	Thousands of DAU answering dozens of questions each — the 100K writes/day ceiling is the one to watch first	D1 usage pricing beyond free allowance, priced per million rows — materially cheaper than a managed Postgres instance at equivalent load
Cloudflare Vectorize	Free allocation of stored + queried dimensions/month	The full 2,000-question target bank plus notes and references, comfortably	Usage-based pricing beyond allocation, low per-query cost
Cloudflare R2	10GB storage, zero egress	Blog imagery, logos, export files for years of content growth	$0.015/GB-month beyond 10GB — no egress charge ever
Cloudflare KV	100K reads/day, 1K writes/day	Rate-limit counters and response caching at moderate traffic	KV usage pricing beyond free allowance
Workers AI (embeddings)	~10,000 neurons/day	Ongoing content publishing and re-indexing at a sustainable editorial pace	Usage-based Workers AI pricing beyond allocation
Firebase Authentication (Spark)	Unlimited email/password + email-link sign-in	No practical ceiling for this project's auth methods	N/A — email/password and email-link stay free at any scale
Resend	3,000 emails/month, 100/day	Early hundreds of active subscribers receiving receipts and digests	Resend paid plans start around $20/month for higher volume
PostHog Cloud	1,000,000 events/month	Well beyond MVP-stage instrumentation volume from Section 9's event list	Usage-based pricing beyond 1M events
Sentry Developer	5,000 errors/month, 1 seat	A well-behaved production app; spikes during hardening should be watched	Team plan, ~$26/month, when more than one engineer needs seats

◆ **NET EFFECT**

Every layer of hosting, database, vector search, storage, caching and authentication runs at **£0/month** through MVP launch and a meaningful runway of organic growth. The two costs that were always going to exist regardless of hosting choice — Anthropic API usage (Ace generation only, since embeddings are free via Workers AI) and Stripe's transaction fees — remain, and both scale with revenue rather than being fixed overhead. The first genuinely necessary paid step, on current figures, is Cloudflare Workers Paid at $5/month once daily API requests pass roughly 100,000/day.

07 Critical Engineering Rules & The 26 Non-Negotiables

⚠ THE 7 ARCHITECTURAL TRAPS TO GUARD AGAINST

1. **Never combine attempt stores.** A single-table design corrupts first-attempt calibration the moment a user resets practice history.
2. **Secondary topics filter only.** They must never double-count toward category coverage totals.
3. **Capture numeric metadata now.** Target, tolerance, units and decimal places must be stored at import so free-text calculation entry can ship later without re-authoring 2,000+ questions.
4. **Multi-sensory feedback.** Correct/incorrect needs a border, an icon, and explicit text — never colour alone (WCAG 2.2 AA).
5. **Uninterrupted completion.** Hitting the free limit on question 30 still shows the full question 30 explanation before any upgrade prompt.
6. **Strict RAG refusal.** Ace answers solely from retrieved chunk context; missing coverage triggers a clear refusal, never a hallucinated inference. Build and test this path first.
7. **Human-in-the-loop gate.** AI-generated questions save as draft and require human reviewer sign-off before entering active pools — enforced in the database, not only the interface.

7.1 The 26 non-negotiable rules (Developer Brief Section 10, verbatim intent)

#	RULE
1	First-attempt performance stays permanently distinguishable from repeated attempts — two stores, first attempts never deleted.
2	Confidence is captured before submission, never after.
3	Explanations analyse every incorrect option, not just the correct answer.
4	Every published question has an owner and a version history.
5	Nothing becomes publicly visible because it was imported.
6	Every analytics view ends with a useful next action.
7	Upgrade prompts never interrupt active learning.
8	Monthly and yearly contain identical features.
9	Cancellation is available online without obstacles.
10	Streaks reward meaningful revision, not opening the application.
11	Mobile question answering is a primary experience.
12	WCAG 2.2 AA is the target.
13	Non-essential cookies stay off until consent.
14	Marketing animation never compromises application speed.
15	No fabricated testimonials, statistics or endorsements.
16	The platform never claims to guarantee exam success.
17	No implied endorsement by the GPhC, NHS, NICE, universities or any other body.
18	The question interface is the most polished area of the product.
19	Avoid the word "mastered" in progress language.
20	Learner data is never deleted on cancellation — locked, not destroyed.

21	Ace answers only from retrieved AcePharm content, never from training data.
22	Ace never publishes — full human review, labelled, generator separated from approver.
23	Every Ace response carries a citation.
24	Ace never gives patient-specific advice.
25	No core feature blocks on an AI call.
26	Flashcards are built from pharmacist-written learning points, not content Ace invents.

7.2 Progress metrics — keep these distinct

METRIC	DEFINITION	SOURCE
First-attempt accuracy	Correct on the very first attempt ever	`question_first_attempts`
Practice accuracy	Correct across all attempts	`question_attempts`
Repeat accuracy	Correct on attempts after the first	`question_attempts, attempt_number > 1`
Confidence calibration	Stated confidence vs actual correctness	Both
Coverage	% of available questions in a subtopic attempted at least once	`question_first_attempts`

Status labels, in order: Not started → First pass → Needs attention → Developing → Secure → Due for review. Never "mastered" — the methodology cannot defend the claim.

08 Phased Implementation Milestones

Seven milestones, unchanged in scope and acceptance criteria from the Developer Brief — updated below only where the Cloudflare/Firebase stack changes the concrete deliverable. Each milestone ends with a Cloudflare Pages preview deployment the client reviews before the next begins.

1 Foundations & Infrastructure

`~10 days`

Cloudflare account, Pages project, Workers project (Hono), D1 database with location hint `weur`, Vectorize index, R2 buckets, KV namespaces — all provisioned via Wrangler and checked into a `wrangler.toml`. Firebase project created, Authentication enabled (email/password + email-link), Admin SDK wired into a Worker for token verification. Drizzle schema covering every Milestone 1–7 entity, including deferred-feature fields. Design tokens in Tailwind config from the prototype's stylesheet. GitHub Actions pipeline running D1 migrations on merge.

Acceptance: Account created via Firebase, verified, and logged in on the Pages preview. A non-admin visiting `/admin` returns HTTP 403, enforced inside the Worker, not just hidden in the UI. D1 migrations run cleanly from empty.

---

2 Content Pipeline & Seed Ingestion

`~8 days`

Curriculum manager, subtopic notes editor, SBA/calculation question editor with mandatory per-option rationales, full review-status state machine, spreadsheet importer with a readable pre-write validation report, R2-backed image uploads for question assets. Import and publish the 135 seed questions across 19 categories — as drafts first, publishing always a separate deliberate action per question.

Acceptance: the complete 135-question seed bank imported through the importer, reviewed and published on staging. Form validation blocks any question lacking individual option rationales.

---

3 The Question Engine & Session Experience

`~14 days — expect the longest, most polished milestone`

Session builder; question screen (desktop and mobile) with confidence-before-submission, optimistic-UI answer feedback under 300ms perceived, hide-options mode, keyboard shortcuts that respect text-field focus, bookmarking, notes, reporting; dual-store writes to `question_first_attempts` and `question_attempts` via a Worker transaction; session summary with review grid.

Acceptance: a 20-question session completes on iOS Safari, Android Chrome and desktop. First-attempt records write once; a category reset clears `question_attempts` for that category while `question_first_attempts` is untouched.

---

4 Dashboard, Calibration Analytics & Recommendations

`~10 days`

Meaningful-session streak (≥5 questions or ≥10 active minutes), timezone-aware daily goal, the explainable recommendation engine (≥5 attempts, lowest first-attempt accuracy, ≥5 unseen questions remaining — falling back to "most unseen questions" and labelled as a starting point when nothing qualifies), first-attempt/practice/repeat accuracy split, confidence-calibration matrix, coverage map, weak-area session generator.

Acceptance: a new account shows clean guided empty states; an account with 100+ attempts shows a recommendation with a visible, honest reason.

---

5 The Ace AI Layer & Vectorize RAG

`~14 days — deliberately after the core product works`

Chunking pipeline on publish; Workers AI embeddings into Vectorize; Ask Ace panel with quick prompts, free text, streaming and highlight-to-ask; thread scoping and full retrieval/cost logging; weekly insight on a Cron Trigger; revision planner; calculation coach; SM-2 flashcards; AI-drafted questions into the existing review workflow with generator/approver separation enforced at the D1 layer; consultation simulator as a database row; 50+ case evaluation set.

Acceptance: Ace answers correctly with citations across all seed subtopics; out-of-coverage and real-patient queries trigger a graceful refusal; with Claude disabled, every other part of the product keeps working.

---

6 Public Marketing Site, SEO & Stripe

`~10 days`

All public pages with verbatim copy from the companion document; database-backed blog with an admin markdown editor; cookie consent gating PostHog initialisation; SEO metadata, JSON-LD, sitemap, noindex on the app/admin shells; Stripe Checkout for both plans, webhook handler on a Worker with signature verification and idempotent handling of all five required event types; two-screen in-app cancellation; transactional emails (Firebase for verify/reset, Resend for the rest).

Acceptance: full journey verified in Stripe test mode end to end on staging: visitor → free account → 30 questions → limit → checkout → unlimited access → self-service cancellation. Lighthouse 90+ on the homepage.

7

Hardening, Accessibility & Launch Readiness

`~8 days`

Remaining admin (user management, reports queue, support tickets, audit log, AI oversight, cost dashboards); full WCAG 2.2 AA audit; D1 index tuning and load-testing the session-builder filter query under simulated volume; CSP headers and app-layer rate limiting verified on every auth and Ace endpoint; automated daily D1 backup via Wrangler export to R2, with a scripted restore test; production Cloudflare zone, live Stripe keys, monitoring dashboards live.

Acceptance: Section 9 launch checklist 100% complete. Zero critical vulnerabilities in an automated security scan. Daily D1 backup restore verified on staging.

09 Accessibility, Security & Compliance

9.1 Accessibility — WCAG 2.2 AA

- ☐ Full keyboard navigation, visible focus states on every interactive element
- ☐ Semantic heading hierarchy, no skipped levels; labelled form controls with linked, specific error messages
- ☐ ARIA live region announces answer results — correct/incorrect never relies on colour alone
- ☐ Text resizes to 200% without loss of function; `prefers-reduced-motion` respected everywhere, including the Ace orb and hero visual
- ☐ Touch targets minimum 44×44px; tables have proper headers and scope
- ☐ No CAPTCHA as the sole authentication route; no auto-playing audio
- ☐ axe-core run in CI; manual keyboard-only and VoiceOver/NVDA pass on the question screen specifically

9.2 Security baseline

Identity & transport

- HTTPS with HSTS at the Cloudflare edge by default
- Password hashing delegated to Firebase Authentication (managed, audited)
- Firebase ID tokens verified server-side on every Worker request — a hidden button is never authorisation
- CSRF protection on all state-changing routes

Application & data

- Rate limiting via Worker + KV sliding windows on login, reset, registration, reporting and every Ace endpoint
- Stripe webhook signature verification, idempotent handlers
- CSP headers set at the Worker/Pages layer; no secrets in the repository — Cloudflare and Firebase secrets stored via Wrangler secrets and environment bindings
- Admins never see passwords (Firebase-managed, not stored in D1 at all)

9.3 Environments

Local (Wrangler dev, local D1 emulation) → Staging (separate D1 database, seeded with the 135 seed questions, password-protected Pages deployment, Stripe test mode, Firebase project in test mode) → Production (region-pinned D1, live Stripe, live Firebase project). Environments are never cross-wired.

10 Brand Voice & Copy Compliance

The Website Copy document is the source of truth for every string in the product — used verbatim, not paraphrased. The tone rules below are a product decision, not a style preference, and QA should check for violations the same way it checks for broken links.

10.1 Voice

Intelligent, calm, precise, supportive. Encouraging but never patronising. Plain British English — "organise", "personalised", "analyse", "programme"; "medicines" not "meds"; micrograms written in full, never "mcg" or "µg"; 12-hour clock ("3:00 pm"); dates as "18 September 2027".

10.2 Banned phrases and preferred alternatives

NEVER WRITE	WRITE INSTEAD
"You failed"	"Not quite. Let's work through it."
"You are falling behind"	"This topic needs another look"
"Don't lose your streak" / "We miss you!"	"You are building consistency"
"Only [X] days left"	"A short session today will keep you on track"
"Cardiology accuracy: 57%" (bare figure)	"Cardiovascular is currently your weakest major topic. A 15-question focused session is ready."
"Wrong!" / "Mastered" / "Guaranteed"	Never used — see the 26 non-negotiables, rules 16 and 19
"Everything you need to pass" / "Complete curriculum coverage"	Not claimed — coverage is shown honestly as a percentage with a next action
Any claim of GPhC / NHS / NICE / university endorsement	Never implied, anywhere in copy or design
"AI-powered" as a standalone selling point	State what Ace does, not what it runs on

⚠ DEFERRED FEATURES — DO NOT BUILD

Per the brief's explicit scope boundary: mock exam engine, achievements/badges, university community/leaderboards, student stories/testimonials (no real testimonials exist), homepage statistics counters (no verified figures), extended-matching question UI (schema supports it, UI does not ship), free-text numeric calculation entry (fields captured, input stays multiple-choice), native apps/PWA/offline mode, dark mode (tokens make it a later config change), voice input/output, multiple simulator scenarios, System Status/Roadmap/Careers pages, and social login. If a build choice seems to need one of these, stop and ask rather than building a placeholder.

11 Verification Plan & Quality Assurance

11.1 Automated testing matrix

Unit & integration (Vitest, incl. `@cloudflare/vitest-pool-workers`)

- Attempt-store isolation: writes to `question_attempts` never pollute `question_first_attempts`
- SM-2 interval/ease-factor progression
- Recommendation engine priority-sorting rules
- Free-tier 30-question boundary and anniversary reset
- D1 migrations run against Miniflare in CI on every PR

End-to-end (Playwright, against Pages preview URLs)

- Registration → Firebase verification → onboarding → session → answering flow
- Timed session countdown, pause, resume, timeout auto-submit
- Stripe checkout and webhook entitlement provisioning in test mode
- Ace panel opening, prompt sending, streamed rendering, citation display

11.2 AI evaluation suite (50+ cases)

Citation accuracy across core subtopics (cardiovascular, respiratory, mental health, palliative care, renal). Refusal tests: real-patient queries, out-of-curriculum queries, and dosing-from-memory prompts must all trigger the graceful refusal path, not an improvised answer. Re-run on every system-prompt or retrieval change — without a fixed evaluation set, a prompt change's effect on quality is unknowable.

11.3 Manual verification checklist

- ☐ Responsive verification on iPhone Safari, Android Chrome, iPad Safari, desktop Chrome/Safari
- ☐ Screen-reader navigation with VoiceOver and NVDA
- ☐ Category practice reset clears `question_attempts` while first-attempt accuracy is unchanged
- ☐ Question and Ace reports appear in the admin moderation queue with auto-attached metadata
- ☐ D1 backup restore drill succeeds on staging before go-live
- ☐ Every banned phrase in Section 10.2 absent from shipped copy — spot-checked against the live build, not just the copy document

12 What The Client Must Supply

ITEM	NEEDED BY
Final category and subtopic list (client finalising; seed bank covers 19 of ~20–26)	Milestone 2
Seed Question Bank v0.1 (135 questions, 27 subtopics)	Milestone 2
Logo files and favicon	Milestone 1
Domain and DNS access (for Cloudflare zone setup)	Milestone 1
List of UK schools of pharmacy	Milestone 1
Anthropic API key	Milestone 5
Approved consultation scenario script and rubric	Milestone 5
Stripe account (live and test keys)	Milestone 6
Founder bio and About page detail	Milestone 6
Email sending domain verification (for Resend)	Milestone 6
Any initial blog articles	Milestone 6
Terms, Privacy, Cookie Policy, Acceptable Use text — including the Firebase data-residency note in Section 2.3	Milestone 7
AI Use Policy text	Milestone 7

Open items that do not block Milestones 1 or 2: final category count (20–26, client finalising), whether the blog stays database-backed as assumed here, and whether support tickets stay in-house (assumed, Milestone 7) or move to a hosted helpdesk.

13 Risk Register — Free-Tier Specific

RISK	LIKELIHOOD	MITIGATION
D1's 100,000 writes/day ceiling is reached by attempt-logging at scale	Medium, post-growth	Monitored via a Cloudflare dashboard alert; upgrading to D1 usage-based pricing is a config change, not a re-platform — no schema or query rewrite required.
Firebase Authentication's identity store is not fully EU-region-pinned	Certain (architectural)	Scoped exposure (email + password hash only); documented in Privacy Policy; confirmed with legal sign-off before launch per Section 2.3.
Cloudflare free-plan WAF rate-limiting allowance is too thin for defence-in-depth	Low	Primary rate limiting implemented at the application layer (Worker + KV), independent of the WAF allowance; Pro plan (~£20/mo) available as an additive hardening step, not a dependency.
Workers AI free embedding allocation is exhausted during a large content re-index	Low, bursty	Re-indexing runs are batched and rate-limited in the Worker; a one-off overage is inexpensive usage-based spend, not a blocker.
Vendor lock-in to Cloudflare's proprietary primitives (D1, Vectorize, KV)	Structural, accepted trade-off	Drizzle's schema layer and the RAG retrieval interface are both abstracted behind repository/service modules, so a future migration to Postgres + pgvector — if growth ever justifies it — touches the data-access layer only, not product logic.
Team unfamiliarity with Cloudflare Workers/D1 versus the more common Vercel/Postgres pairing	Project-dependent	Per the brief's own override rule: if the build team is not fluent in this stack, say so before Milestone 1 and propose the equivalent they know well, rather than switching silently mid-build.

This plan re-derives infrastructure only. Every product rule, data rule, UI/UX decision and piece of copy in the Developer Brief v2.1, the Website Copy v2.0, and the interactive prototype remains authoritative and unchanged. Where this document and those source documents appear to disagree on anything other than hosting, the source documents win — raise it with the client rather than resolving it silently.